

Email Security Posture Assessment

spoofable.example

24

F

High risk

Scan date	18 September 2026, 20:43 UTC
Scan ID	29607807672a
Checks run	7
Findings	3 failing, 2 warnings, 0 passing
Narrative	Rule-based (built-in)
Engine version	1.0.0

Executive summary

spoofable.example scores 24/100 (F) — high risk. The assessment found 2 critical and 3 lower-severity issues. The most consequential — No DMARC record published — matters because: No DMARC policy exists at _dmarc.spoofable.example. Nothing instructs receiving servers what to do with mail that fails SPF or DKIM, and no one receives reports about who is sending as this domain. In practice this means the domain can be spoofed in phishing and business-email-compromise campaigns with no enforcement standing in the way. The practical consequence is that spoofable.example is currently spoofable: an attacker can put your domain in the From: header of a phishing or invoice-fraud message and receiving servers have no instruction to stop it.

What an attacker could do with this

- An attacker can send mail with your exact domain in the From: header and no receiving server has instructions to reject it. The usual play is an invoice or payment-detail change sent to your finance team or your customers, arriving from what looks precisely like your domain.
- The record explicitly authorises every host on the internet to send as your domain. An attacker's mail does not merely evade SPF — it passes it.
- If no DKIM signature is applied, forwarded mail loses SPF alignment and DMARC has only one signal left to work with, which increases both spoofing exposure and false rejections of your own legitimate mail.
- Without MTA-STS, an on-path attacker strips the STARTTLS advertisement from your server's greeting. The sending server sees a host that does not support TLS, falls back to cleartext, and delivers the message in the clear. Neither side sees an error.
- No one receives reports of failed TLS negotiations, so a downgrade attack or an expired certificate on your MX produces no alert to your team.

Narrative generated by the built-in rule-based writer. Reason: LLM disabled for this scan

Score by category

Category	Earned	Available	Result
Authentication	10.5	65.0	16%
Policy & Reporting	7.6	10.0	76%

Excluded from scoring because the check could not complete: transport. These are neither counted as passing nor as failing — the score is calculated over the checks that returned a conclusive result.

Findings

[CRITICAL] SPF record ends in `+all`

`+all` tells every receiver that any host on the internet is an authorised sender for this domain. This is strictly worse than publishing no SPF record, because it converts SPF from a control into an explicit authorisation of any sender.

```
record = v=spf1 +all
qualifier = +
```

Fix: Replace `+all` with `-all` and enumerate legitimate senders.

Reference: RFC 7208 §5.1

[CRITICAL] No DMARC record published

No DMARC policy exists at `_dmarc.spoofable.example`. Nothing instructs receiving servers what to do with mail that fails SPF or DKIM, and no one receives reports about who is sending as this domain. In practice this means the domain can be spoofed in phishing and business-email-compromise campaigns with no enforcement standing in the way.

```
queried = _dmarc.spoofable.example
records_found = 0
```

Fix: Publish a TXT record at `_dmarc.spoofable.example`, starting at "v=DMARC1; p=none; rua=mailto:dmarc@yourdomain" to collect reports, then move to p=quarantine and finally p=reject.

Reference: RFC 7489 §6.3

[MEDIUM] No DKIM key found at any probed selector

None of the 41 selectors commonly used by mail platforms resolved for `spoofable.example`. DKIM selectors cannot be enumerated from DNS, so this does not prove DKIM is absent — the domain may sign with a custom selector this scan did not guess. Confirm by inspecting the DKIM-Signature header of a message sent from the domain.

```
selectors_probed = 41
selectors = ['google', 'selector1', 'selector2', 'k1', 'k2', 'k3', 's1', 's2', 'mail', 'dkim', 'default', 'smtp', 'email', ...]
```

Fix: If DKIM is not configured, enable signing at your mail provider and publish the selector key. If it is configured under a custom selector, supply it to this tool for an accurate reading.

Reference: RFC 6376 §3.6

[MEDIUM] MTA-STS is not configured

No MTA-STS record exists at `_mta-sts.spoofable.example`. SMTP's opportunistic TLS can be stripped by an on-path attacker simply by removing the STARTTLS advertisement from the server greeting — the sending server then delivers the message in cleartext and nothing alerts either party. MTA-STS is the mechanism that makes TLS mandatory and detectable for inbound mail.

```
queried = _mta-sts.spoofable.example
records_found = 0
```

Fix: Publish TXT "v=STSV1; id=<timestamp>" at `_mta-sts.spoofable.example` and host a policy file at `https://mta-sts.spoofable.example/.well-known/mta-sts.txt`, starting in mode: testing before moving to mode: enforce.

Reference: RFC 8461 §3

[LOW] TLS-RPT is not configured

No TLS-RPT record at `_smtp._tls.spoofable.example`. Sending servers have nowhere to report failed TLS negotiations, so a downgrade attack or an expired certificate on your MX would produce no signal to your team — you would learn about it from users, if at all.

```
queried = _smtp._tls.spoofable.example
records_found = 0
```

Fix: Publish TXT "`v=TLSRPTv1; rua=mailto:tls-reports@spoofable.example`" at `_smtp._tls.spoofable.example`.

Reference: RFC 8460 §3

Not assessed

— BIMI is not configured: No BIMI record found. BIMI displays a verified brand logo beside authenticated mail; it is optional, requires DMARC at enforcement first, and its absence is not a security weakness.

— TLS probing was disabled for this scan: 1 MX host(s) were discovered but not contacted.

Remediation plan

Ordered by risk reduced, not by effort required.

#	Action	Severity
1	Publish a TXT record at <code>_dmarc.spoofable.example</code> , starting at " <code>v=DMARC1; p=none; rua=mailto:dmarc@yourdomain</code> " to collect reports, then move to <code>p=quarantine</code> and finally <code>p=reject</code> .	critical
2	Replace <code>`+all`</code> with <code>`-all`</code> and enumerate legitimate senders.	critical
3	If DKIM is not configured, enable signing at your mail provider and publish the selector key. If it is configured under a custom selector, supply it to this tool for an accurate reading.	medium
4	Publish TXT " <code>v=STSV1; id=</code> " at <code>_mta-sts.spoofable.example</code> and host a policy file at <code>https://mta-sts.spoofable.example/.well-known/mta-sts.txt</code> , starting in mode: testing before moving to mode: enforce.	medium
5	Publish TXT " <code>v=TLSRPTv1; rua=mailto:tls-reports@spoofable.example</code> " at <code>_smtp._tls.spoofable.example</code> .	low

Method and scope

This assessment is passive and read-only. It consists of public DNS lookups (SPF, DKIM, DMARC, MTA-STS, TLS-RPT and BIMI records), an HTTPS GET of the domain's published MTA-STS policy file, and SMTP connections to the mail hosts the domain itself advertises in its MX records, used to observe the server's own STARTTLS advertisement and complete a TLS handshake.

The assessment does not send test phishing messages, does not attempt authentication or authentication bypass, does not relay or deliver mail, does not access mailbox contents, and does not attempt to exploit any weakness it identifies. No credentials are used and no data is submitted to the target. Connections are closed with QUIT and are rate-limited per domain.

Scoring assigns each check a share of 100 points weighted by the attacker leverage a failure grants (dmarc 30, transport 25, spf 20, dkim 15, mta_sts 7, tls_rpt 3). Each finding removes a fraction of its check's points by severity: critical 100%, high 60%, medium 30%, low 10%. A check that could not complete is removed from the denominator rather than counted as a failure, so a network restriction on the scanner is never reported as a

weakness in the assessed domain.

The narrative section is generated from the findings above and is constrained to them: it cannot introduce a finding the engine did not produce, and any generated text that references an unknown finding or states a score other than the computed one is rejected and replaced by the built-in rule-based writer.

Generated 18 September 2026 at 20:44 · Scan ID 29607807672a